Gap Analysis: E-Commerce API

Step 7 of the Postman BA mini project | Based on test cases TC-01 to TC-12 and user stories US-01 to US-08 (DummyJSON)

Purpose

A gap analysis compares what the business needs with what the API actually does. Each row below states a business need, what was observed in Postman, whether the API supports the need, how much it matters, and what to do about it. Findings come only from the test results; anything not yet tested is marked **To verify** rather than guessed.

Status legend

Status	Meaning
Supported	Observed in the test results and meets the need
Partially supported	Part of the need is met, part is missing or untested
Not supported	Observed behavior does not meet the need
To verify	Not tested yet; check in Postman before drawing a conclusion
Pending re-run	Depends on TC-12, which must be re-run as POST /products/add with body {}

Gap summary

ID	Business need	Status	Impact	Linked stories
G-01	Only authorized admins can add, update or delete products	Not supported	High	US-08, US-05, US-06, US-07
G-02	Invalid or incomplete product data is rejected	Pending re-run	High	US-05
G-03	Product changes are actually saved	To verify	High	US-05, US-06, US-07
G-04	The product list loads quickly and in manageable pages	Partially supported	Medium	US-03
G-05	Customers can search, filter and sort products	To verify	Medium	US-03
G-06	Customers stay logged in without re-entering their password	Partially supported	Medium	US-01, US-02
G-07	Clear error messages for failed requests	Supported	Low	US-01, US-02, US-04
G-08	Customers can see stock availability	Supported	Low	US-04

G-01: Only authorized admins can change products

Business need: Customers must not be able to add, update or delete products.

Status: Not supported | **Impact:** High

Finding: TC-05, TC-06 and TC-07 all succeeded with no access token (Auth Needed? = No for every product-changing call).

Evidence: TC-05, TC-06, TC-07

Recommendation: Require a valid token on add, update and delete and check the admin role; return 401 for a missing or invalid token and 403 for a non-admin user. Treat as a must-have before any real release.

Linked stories: US-08, US-05, US-06, US-07

G-02: Invalid or incomplete product data is rejected

Business need: The catalog must not fill with empty or broken products.

Status: Pending re-run | **Impact:** High

Finding: Original TC-12 put {} in the URL and returned 404, so validation was not tested; expected 400 is a BA assumption.

Evidence: TC-12 (pending)

Recommendation: If an empty product is accepted, require validation of mandatory fields (such as title and price) and a 400 response naming the missing fields.

Linked stories: US-05

G-03: Product changes are actually saved

Business need: After an admin adds, updates or deletes a product, the catalog must reflect the change.

Status: To verify | **Impact:** High

Finding: TC-05 to TC-07 returned success responses but no follow-up GET was done; public demo APIs often simulate writes.

Evidence: TC-05, TC-06, TC-07 (success responses only)

Recommendation: If changes are not stored, note the API is suitable for prototyping only and that a real backend must persist data.

Linked stories: US-05, US-06, US-07

G-04: The product list loads quickly and in manageable pages

Business need: Browsing the catalog should feel fast and should not return everything at once.

Status: Partially supported | **Impact:** Medium

Finding: List returns 200 with nested product data, but 2,900 ms was the slowest response in the run (above the proposed 2,000 ms target); paging not tested; timings are from a single run.

Evidence: TC-03

Recommendation: Agree a response-time target with the business, require paging with a sensible default page size, and repeat timings several times.

Linked stories: US-03

G-05: Customers can search, filter and sort products

Business need: Customers should be able to narrow the catalog by keyword or category and sort by price.

Status: To verify | **Impact:** Medium

Finding: Not tested; test cases only covered listing all products and fetching one by ID.

Evidence: None yet

Recommendation: Check the API documentation for search, category and sort options and add test cases; if missing, raise an enhancement request.

Linked stories: US-03

G-06: Customers stay logged in without re-entering their password

Business need: A session should be renewable so customers are not logged out constantly.

Status: Partially supported | **Impact:** Medium

Finding: Login returns a refresh token and an invalid or expired access token is rejected with a clear message; the refresh flow itself has not been tested.

Evidence: TC-01, TC-10

Recommendation: Test the token refresh request, document how long tokens last, and define what the customer sees when a session expires.

Linked stories: US-01, US-02

G-07: Clear error messages for failed requests

Business need: Failures should tell the user or developer what went wrong.

Status: Supported | **Impact:** Low

Finding: Wrong credentials return 400 "Invalid Credentials"; missing and invalid tokens return different 401 messages; a missing product returns 404 with the product ID in the message.

Evidence: TC-08, TC-09, TC-10, TC-11

Recommendation: No change needed; reuse these messages as the wording standard in requirements and acceptance criteria.

Linked stories: US-01, US-02, US-04

G-08: Customers can see stock availability

Business need: Customers should know whether a product is available before buying.

Status: Supported | **Impact:** Low

Finding: The single-product response includes a stock field.

Evidence: TC-04

Recommendation: No change needed; use the stock field for availability display in the UI requirements (low-stock warnings would be a separate, untested need).

Linked stories: US-04

Overall conclusion

The API covers the read-only customer journey well: login, profile, browsing, product details and clear errors. The main risks are on the admin side. Product changes need access control (G-01), input validation (G-02) and confirmation that data is really saved (G-03). The list performance and paging (G-04), search and filtering (G-05) and the token refresh flow (G-06) are the next items to investigate.

Assumptions and notes

- The 2,000 ms response-time target is a BA proposal from Step 6, not an agreed business requirement.
- Impact ratings are the BA's judgment and should be confirmed with stakeholders.
- Status values will change as the To verify and Pending re-run items are tested.

Next steps

1. Re-run TC-12 and update G-02.
2. Run GET checks after add, update and delete to settle G-03.
3. Test pagination, search, filter and sort options (G-04, G-05) and the token refresh request (G-06).
4. Update the status of each gap, then move on to the login flow diagram (Step 8).